

Name: Toh Qi Hao

UOW ID: 8931914

Question 1:

1) All listed parties, a to e can potentially observe which fiction the user is reading because the book display and book reading services use HTTP so the request URL and query parameter such as bookID and sessionID are not encrypted, therefore users on the same wifi, the Wi-Fi administrator, the internet service provided and intermediate server administrators may observe the traffic. The website administrator can observe it because the website directly receives and logs the user's book request

2) A VPN can hide the user's reading activity from local Wi-Fi users, the shopping centre Wi-Fi administrator, the ISP, and network administrators because the traffic is encrypted between the user and the VPN server. However, the user is not fully anonymous because the VPN server can observe outgoing traffic and the website administrator can still know which logged-in user is reading which book.

3) Yes. The book reading page uses HTTP, the VPN server can observe the unencrypted request after the VPN tunnel ends. The URL may include parameters such as bookID and sessionID, allowing the VPN server to determine which book the user is reading. If the website used HTTPS for book reading, the VPN server would not be able to see the full path or query parameters.

4) 1. Passive network attacker: Eavesdropping

A passive network attacker on the same public Wi-Fi can observe unencrypted HTTP traffic. Since the book reading page uses HTTP, the attacker may see the book URL and query parameters such as bookID and sessionID.

This threatens the user's privacy because the attacker can learn which fiction the user is reading without modifying the traffic.

2. Gadget attacker: Cross-Site Scripting (XSS)

A gadget attacker can exploit the website's customer review function because the scenario says no specific security mechanisms are applied to user input. If the attacker submits a malicious script inside a book review, other users who view the review may have the script executed in their browser.

This is a client-side threat because the attack runs in the victim's browser and may steal session information, modify page content, or perform actions as the user.

3. Active network attacker: Script injection

An active network attacker can intercept and modify HTTP traffic between the user and the website. Since the book display and book reading pages use HTTP, the attacker may inject malicious JavaScript into the page before it reaches the user's browser.

This allows the attacker to manipulate the client-side content and potentially steal information or perform actions using the user's session.

5) A defence-in-depth strategy should be used because no single control is perfect. HTTPS and HSTS protect against passive and active network attackers by encrypting traffic and preventing HTTP downgrade. Input validation, output encoding, and CSP protect against gadget attackers who attempt XSS through customer reviews. Secure cookie attributes such as HttpOnly, Secure, and SameSite reduce the impact of session theft and cross-site attacks. Together, these controls protect confidentiality, integrity, and session security.

Question 2:

1) Only No. 4, No. 5, and No. 6 are allowed. Only No. 4 and No. 5 are scripts that execute, while No. 6 is an image that loads, not a script.

2) Content-Security-Policy:

```
default-src 'none'; style-src 'self';  
script-src 'self' 'nonce-abc123';  
img-src 'self';  
frame-src 'none';  
frame-ancestors 'self';
```

Question 3:

1) Alice has visited `https://play.com` before, so her browser has stored the HSTS policy for `play.com`. When Alice visits `https://example.com`, the hidden request to `http://play.com` will be automatically upgraded by her browser to `https://play.com`. Bob has not visited `https://play.com` before, and `play.com` is not listed in HSTS Preload. Therefore, Bob's browser has not stored the HSTS policy for `play.com`, so the hidden request to `http://play.com` may remain as HTTP. Thus, `example.com` can distinguish Alice from Bob by observing whether the hidden request to `play.com` is upgraded to HTTPS or remains HTTP.

1a) Yes, this can also be used to distinguish multiple users. The administrator can use multiple HSTS-enabled domains or subdomains as tracking bits. For example, if a browser has HSTS stored for some domains but not others, this creates a unique pattern that can identify or distinguish users. However, this tracking may fail if users clear browser data, use private browsing, or use browsers with privacy protections

2) TLS and HSTS Preload protect users by preventing HTTP downgrade and website impersonation. If `bank.com` is listed in HSTS Preload, the browser already knows that `bank.com` must only be accessed using HTTPS, even before the user visits the website for the first time. Therefore, if the user types `http://bank.com`, the browser will automatically upgrade it to `https://bank.com`. TLS then checks whether the server has a valid certificate for `bank.com`. If an attacker redirects the request to an attacker-controlled server, the attacker should not have a valid TLS certificate for `bank.com`. As a result, the browser will reject the connection or show a certificate warning. Therefore, HSTS Preload prevents the attacker from forcing users onto insecure HTTP, while TLS prevents the attacker from successfully pretending to be the real `bank.com` website.